UNIVERSIDAD POLITÉCNICA DE SAN LUIS POTOSÍ

03 - ISO27

CNO IV Programación WAP

Maestro: Servando López Contreras

Lopez Alcocer Monica Isabel - 179827

Contenido

01 Sección 01 — Alcance
02 Sección 02 — Referencias normativas
03 Sección 03 — Términos y definiciones
04 Sección 04 — Contexto de la organización (activos)
05 Sección 05 — Liderazgo (política y 20 políticas funcionales)
06 Sección 06 — Planificación (matriz de riesgos)
07 Sección 07 — Soporte (minuta y prevención)
08 Sección 08 — Operación (matriz RACI)
09 Sección 09 — Evaluación del desempeño (checklists)
10 Sección 10 — Mejora

Cómo leer este documento. Cada riesgo y control se vincula con los 20 hallazgos reales obtenidos durante el ejercicio INTERAFAS-LAB, explicando de qué manera el control de ISO/IEC 27001 previene, detecta, limita o responde ante situaciones similares.

Sección 01 — Alcance

1.1 La organización

INTERAFAS (Infraestructura y Red Metropolitana de Agua, Alcantarillado, Saneamiento y Resiliencia) es el organismo operador descentralizado responsable del abastecimiento de agua potable, el alcantarillado y el saneamiento de la zona metropolitana. Opera una red física y digital que integra estaciones de bombeo, PLCs, RTU y telemetría en Cerro de San Pablo, Saint Louis y Soledade, además de un portal ciudadano para trámites, pagos y atención.

Elemento	Declaración
Misión	Garantizar el suministro continuo, seguro y de calidad de agua potable, alcantarillado y saneamiento a la población metropolitana, operando con eficiencia, resiliencia y responsabilidad social.
Visión	Ser para 2030 el organismo operador de referencia nacional en gestión hídrica digitalizada, confiable y segura, protegiendo tanto la operación física (OT) como la información de la ciudadanía.
Objetivos	(1) Continuidad y seguridad del servicio; (2) calidad del agua dentro de norma; (3) protección de datos personales; (4) ciberseguridad IT y OT; (5) cumplimiento legal y regulatorio.
Historia	Organismo público creado para consolidar la operación metropolitana del agua. Su digitalización acelerada (portal, API, telemetría y actualización remota de firmware) amplió su superficie de exposición y motivó la adopción formal de un SGSI.

1.2 Organigrama

Dirección General		
Oficial de Seguridad de la Información (CISO) — asesor directo de la Dirección General		
Dir. de Operaciones (OT)	**Dir. de Tecnologías de la Información**	**Dir. Comercial / Atención Ciudadana**
Estaciones, PLC, RTU, telemetría, firmware	Portal, API, redes, desarrollo	Cuentas, pagos, expedientes
Dir. de Administración	**Unidad de Transparencia / Oficial de Datos**	**Jurídico**
Proveedores y contratos	PII, datos abiertos	Cumplimiento legal y regulatorio

El CISO se crea como función transversal con línea directa a la Dirección General para garantizar independencia respecto de TI y OT.

1.3 Presentación del proyecto a la Alta Dirección

Se propone a la Dirección General la implementación de un Sistema de Gestión de Seguridad de la Información (SGSI) conforme a ISO/IEC 27001:2022. El proyecto nace de una evaluación de seguridad ofensiva (INTERAFAS-LAB) que confirmó 20 vulnerabilidades, desde fugas de información hasta un impacto operacional catastrófico simulado en la infraestructura crítica de agua.

Parámetro del proyecto	Definición
Dirección patrocinadora	Dirección General de INTERAFAS (liderazgo y recursos, cláusula 5).
Área ejecutora	Oficina del CISO, con participación de las Direcciones de TI y de Operaciones (OT).
Proceso donde se ejecuta	Gestión de servicios digitales ciudadanos (portal, API, pagos) y operación del proceso de agua (telemetría, gateway, PLC, firmware).
Alcance del SGSI	Portal web ciudadano y su API; datos personales y de pago; infraestructura y frontera IT/OT (RTU-GW-07, PLC, telemetría, canal de firmware); bitácoras. Incluye los 20 activos de la Sección 04.
Exclusiones	Procesos físicos no digitalizados y sistemas administrativos sin relación con los activos del alcance (Declaración de Aplicabilidad).

Sección 02 — Referencias normativas

De la familia de normas ISO/IEC 27000 (y normas afines para infraestructura crítica), se seleccionan las de mayor interés para INTERAFAS dado su perfil IT/OT y de datos personales:

Norma	Relevancia para INTERAFAS
ISO/IEC 27000	Vocabulario y visión general del SGSI; base conceptual para la Alta Dirección.
ISO/IEC 27001:2022	Requisitos del SGSI; norma certificable que estructura este documento (cláusulas 4–10).
ISO/IEC 27002:2022	Guía de los 93 controles del Anexo A; referencia para las políticas funcionales (Sección 05).
ISO/IEC 27005	Gestión de riesgos; sustenta la matriz de riesgos (Sección 06).
ISO/IEC 27019	Controles para sistemas de control de procesos de servicios públicos (agua/energía); clave para la operación OT (A06–A09).
ISO/IEC 27017 / 27018	Seguridad y protección de PII en servicios de nube; hosting y datos ciudadanos (A11, A19).
ISO/IEC 27035	Gestión de incidentes de seguridad; respuesta ante la explotación de los hallazgos.
ISO/IEC 27031 / ISO 22301	Continuidad de TIC y del negocio; disponibilidad del servicio de agua (A07, A19).
IEC 62443	Seguridad de sistemas de automatización y control industrial; frontera IT/OT y firmware.

2.1 Marco legal y regulatorio aplicable

Ordenamiento	Obligación principal
LGPDPPSO	Como ente público, INTERAFAS debe proteger los datos personales de los ciudadanos (A11, A13) con medidas de seguridad y avisos de privacidad.
LFPDPPP	Aplicable a tratamientos con proveedores privados; deberes de seguridad y derechos ARCO.
Ley General de Transparencia y Acceso a la Información Pública	Obligaciones de transparencia (A16), equilibradas con la clasificación de datos internos.

Ordenamiento	Obligación principal
Ley de Aguas Nacionales y normativa estatal de agua	Obligaciones como organismo operador y de reporte ante CONAGUA y la autoridad estatal.
NOM-151-SCFI / lineamientos del INAI	Conservación e integridad de mensajes de datos y seguridad de datos personales.

El inventario completo de obligaciones se mantiene vivo por el área Jurídica y se verifica en la Sección 09.

Sección 03 — Términos y definiciones

Términos de ISO/IEC 27000 necesarios para que la Alta Dirección contextualice la propuesta:

Término	Definición (adaptada de ISO/IEC 27000)
Seguridad de la información	Preservación de la confidencialidad, integridad y disponibilidad de la información.
Confidencialidad	La información no se divulga a individuos, entidades o procesos no autorizados (hallazgo 03).
Integridad	Exactitud y completitud de la información (evitar la manipulación de pagos del hallazgo 13).
Disponibilidad	La información es accesible y utilizable cuando una entidad autorizada lo requiere (continuidad del proceso, hallazgo 20).
Activo de información	Elemento con valor para la organización (datos, sistemas, infraestructura); se inventarían 20 en la Sección 04.
Amenaza	Causa potencial de un incidente no deseado que puede dañar un activo.
Vulnerabilidad	Debilidad de un activo o control que una amenaza puede explotar (cada uno de los 20 hallazgos).
Riesgo	Efecto de la incertidumbre sobre los objetivos; combinación de probabilidad e impacto.
Control	Medida que modifica o trata el riesgo (controles del Anexo A de ISO/IEC 27002).
SGSI	Conjunto de políticas, procesos y recursos para gestionar el riesgo de forma sistemática.

Sección 04 — Contexto de la organización

Se definen 20 activos de información (10 internos y 10 externos) que delimitan el alcance del SGSI, con su dueño, clasificación C/I/D y el hallazgo que evidenció su exposición.

4.1 Activos internos

ID	Activo de información	Dueño	C	I	D	Hallazgo
A01	Base de datos de cuentas y expedientes ciudadanos (PII)	Dir. Comercial (dueño del dato) / Dir. TI (custodio)	A	A	A	03, 11, 12
A02	Portal web ciudadano (aplicación)	Dir. TI	M	A	A	05, 06, 08
A03	API interna de servicios (/api/*)	Dir. TI	A	A	M	11, 12
A04	Código fuente y artefactos de despliegue	Dir. TI	A	M	B	01, 02, 04
A05	Credenciales y secretos (tokens, config.php, cuentas de soporte)	Oficial de Seguridad (CISO)	A	A	M	01, 02, 10, 18
A06	Sistema de telemetría y vista HMI (OT)	Dir. Operaciones (OT)	A	A	A	17
A07	Gateway operacional RTU-GW-07 y frontera IT/OT	Dir. Operaciones (OT)	A	A	A	15, 16
A08	PLCs y lógica de control de proceso (cadena de dependencias)	Dir. Operaciones (OT)	M	A	A	19
A09	Firmware OT y canal de actualización	Dir. Operaciones (OT)	M	A	A	18, 20
A10	Bitácoras y registros de auditoría	Oficial de Seguridad (CISO)	M	A	M	Transversal

4.2 Activos externos

ID	Activo de información	Dueño	C	I	D	Hallazgo
A11	Datos personales de ciudadanos (en uso y en tránsito)	Dir. Comercial / Oficial de Datos	A	A	M	03, 12
A12	Información de pagos y pasarela bancaria	Dir. Comercial	A	A	A	13
A13	Expedientes y recibos entregados a ciudadanos	Dir. Comercial	A	M	M	03
A14	Padrón de proveedores y contratos	Dir. Administración	M	A	M	14
A15	Firmware y paquetes del fabricante OT	Dir. Operaciones (OT)	M	A	A	18
A16	Portal de transparencia y datos abiertos (observatorio)	Unidad de Transparencia / Dir. TI	B	M	M	05, 15
A17	Reportes ciudadanos (contenido generado por usuarios)	Dir. Comercial	B	A	M	08
A18	Información y obligaciones regulatorias (CONAGUA / INAI)	Dir. General / Jurídico	M	A	M	Cumplimiento
A19	Servicios y datos en la nube del proveedor de hosting	Dir. TI	M	M	A	Disponibilidad
A20	Accesos de soporte externo (cuenta soporte.ot)	Dir. Operaciones / CISO	A	A	M	18

C/I/D: A = Alta, M = Media, B = Baja. Clasificación conforme a A.5.12 (Clasificación de la información).

Sección 05 — Liderazgo

5.1 Política general de seguridad de la información

La Dirección General de INTERAFAS declara su compromiso con la protección de la confidencialidad, integridad y disponibilidad de la información y de la infraestructura crítica que opera. INTERAFAS establece, implementa y mejora de forma continua un SGSI conforme a ISO/IEC 27001:2022, gestiona los riesgos con criterios definidos, cumple la legislación aplicable en materia de datos personales y agua, protege la frontera entre sus

entornos de información (IT) y de operación (OT), y promueve la cultura de seguridad en todo su personal y proveedores. Esta política es comunicada, revisada anualmente y respaldada con los recursos necesarios.

Aprobada por la Dirección General · Responsable de mantenimiento: CISO · Revisión: anual.

5.2 Políticas funcionales por activo (20)

Cada política funcional integra estándar (control de referencia), directriz (regla de alto nivel), procedimiento (cómo se implementa) y línea base (meta medible). Todas responden a un hallazgo real del lab.

PF-01 · Base de datos de cuentas y expedientes ciudadanos (PII)

Activo A01 (Interno) · Control ISO: A.5.34 · A.8.3 · A.5.15 · Hallazgos: 03, 11, 12

Estándar. ISO/IEC 27002 A.8.3 (Restricción de acceso) y A.5.34 (Privacidad y protección de PII).

Directriz. Todo acceso a cuentas o expedientes valida la titularidad a nivel de objeto contra la sesión.

Procedimiento. Verificación propietario = sesión en cada endpoint; identificadores no predecibles; bitácora de accesos a PII; revisión trimestral.

Línea base. 0 accesos IDOR verificados; 100% de accesos a PII registrados y conciliados.

PF-02 · Portal web ciudadano (aplicación)

Activo A02 (Interno) · Control ISO: A.8.28 · A.8.26 · A.8.9 · Hallazgos: 05, 06, 08

Estándar. ISO/IEC 27002 A.8.28 (Codificación segura) y A.8.26 (Requisitos de seguridad de aplicaciones).

Directriz. El desarrollo y despliegue del portal sigue un ciclo de vida seguro con endurecimiento en producción.

Procedimiento. Análisis SAST/DAST en el pipeline; depuración desactivada en producción; CSP y cabeceras de seguridad; revisión de código.

Línea base. 0 vulnerabilidades críticas en producción; CSP activa en el 100% de las vistas.

PF-03 · API interna de servicios (/api/*)

Activo A03 (Interno) · Control ISO: A.8.26 · A.8.3 · A.5.15 · Hallazgos: 11, 12

Estándar. OWASP API Security Top 10 (2023) e ISO/IEC 27002 A.8.3.

Directriz. Toda la API aplica autorización a nivel de objeto y de función, con inventario gobernado.

Procedimiento. Inventario de endpoints; gateway con autenticación; pruebas específicas de BOLA; denegación por defecto.

Línea base. 100% de endpoints inventariados y autenticados; 0 endpoints “sombra”.

PF-04 · Código fuente y artefactos de despliegue

Activo A04 (Interno) · Control ISO: A.8.4 · A.8.9 · A.8.12 · Hallazgos: 01, 02, 04

Estándar. ISO/IEC 27002 A.8.4 (Acceso al código fuente) y A.8.9 (Gestión de la configuración).

Directriz. Los artefactos de build/despliegue se mantienen fuera de la raíz web servida.

Procedimiento. Pipeline que excluye .env, .bak y manifiestos; escaneo de secretos; bloqueo de extensiones sensibles en el servidor.

Línea base. 0 archivos sensibles accesibles públicamente; 0 secretos en el repositorio.

PF-05 · Credenciales y secretos (tokens, config.php, cuentas de soporte)

Activo A05 (Interno) · Control ISO: A.8.24 · A.5.17 · A.8.5 · Hallazgos: 01, 02, 10, 18

Estándar. ISO/IEC 27002 A.5.17 (Información de autenticación) y A.8.24 (Uso de criptografía).

Directriz. Los secretos se almacenan fuera del webroot, cifrados y con rotación periódica.

Procedimiento. Bóveda de secretos; hashing moderno (bcrypt/Argon2) para contraseñas; MFA para cuentas de soporte; rotación programada.

Línea base. 0 secretos en el webroot/repositorio; hashing ≥ bcrypt; rotación ≤ 90 días.

PF-06 · Sistema de telemetría y vista HMI (OT)

Activo A06 (Interno) · Control ISO: A.5.15 · A.8.5 · A.8.16 · Hallazgos: 17

Estándar. IEC 62443 e ISO/IEC 27002 A.5.15 (Control de acceso).

Directriz. Toda vista o servicio OT exige una sesión de operador válida.

Procedimiento. Autenticación obligatoria en todos los endpoints OT; denegación por defecto; monitoreo de accesos sin sesión.

Línea base. 0 endpoints OT accesibles sin autenticación.

PF-07 · Gateway operacional RTU-GW-07 y frontera IT/OT

Activo A07 (Interno) · Control ISO: A.8.22 · A.8.20 · A.8.12 · Hallazgos: 15, 16

Estándar. ISO/IEC 27002 A.8.22 (Segregación de redes) y A.8.20 (Seguridad de redes).

Directriz. La frontera IT/OT se controla por segmentación real; no se confía en cabeceras del cliente.

Procedimiento. Firewall industrial / DMZ OT; prohibición de X-Forwarded-For para autorización; ocultamiento de metadatos de infraestructura.

Línea base. 0 cruces IT→OT sin pasar por el firewall; 0 metadatos internos expuestos.

PF-08 · PLCs y lógica de control de proceso (cadena de dependencias)

Activo A08 (Interno) · Control ISO: A.5.15 · A.8.16 · ISO 27019 · Hallazgos: 19

Estándar. ISO/IEC 27019 (seguridad para sistemas de control de procesos de servicios públicos).

Directriz. La enumeración de activos y dependencias aplica límites de autorización por rol en el servidor.
Procedimiento. Activar el límite de dependencias (server_enforced_dependency_boundary); monitorear la travesía de la cadena.
Línea base. Límite de dependencias forzado por el servidor = verdadero; 0 recorridos completos sin autorización.

PF-09 · Firmware OT y canal de actualización

Activo A09 (Interno) · Control ISO: A.8.19 · A.8.32 · A.8.24 · Hallazgos: 18, 20

Estándar. ISO/IEC 27002 A.8.19 (Instalación de software) y A.8.32 (Gestión de cambios).
Directriz. Todo firmware/configuración se instala sólo con firma del emisor verificada y rangos operacionales validados.
Procedimiento. Verificación de firma digital del fabricante; validación de rangos de setpoint en el servidor; aprobación formal del cambio.
Línea base. 100% de firmware verificado por firma; 100% de parámetros dentro de rango seguro.

PF-10 · Bitácoras y registros de auditoría

Activo A10 (Interno) · Control ISO: A.8.15 · A.8.16 · Hallazgos: Transversal

Estándar. ISO/IEC 27002 A.8.15 (Registro) y A.8.16 (Actividades de monitoreo).
Directriz. Los eventos de seguridad se registran de forma íntegra y se monitorean de forma continua.
Procedimiento. Logging centralizado; protección de integridad (sello/append-only); alertas ante eventos críticos.
Línea base. 100% de eventos críticos registrados y monitoreados; retención ≥ 12 meses.

PF-11 · Datos personales de ciudadanos (en uso y en tránsito)

Activo A11 (Externo) · Control ISO: A.5.34 · A.8.12 · A.5.14 · Hallazgos: 03, 12

Estándar. LGPDPPSO e ISO/IEC 27002 A.5.34 (Privacidad y protección de PII).
Directriz. Los datos personales se minimizan, cifran y tratan conforme a la ley y al aviso de privacidad.
Procedimiento. Cifrado en tránsito y reposo; control de acceso; avisos de privacidad; atención de derechos ARCO.
Línea base. 100% de PII cifrada; 0 fugas de datos personales confirmadas.

PF-12 · Información de pagos y pasarela bancaria

Activo A12 (Externo) · Control ISO: A.8.26 · A.5.14 · A.8.9 · Hallazgos: 13

Estándar. PCI-DSS e ISO/IEC 27002 A.8.26 (Requisitos de seguridad de aplicaciones).
Directriz. La titularidad y el monto de todo pago se validan y calculan del lado del servidor.
Procedimiento. Verificación factura – cuenta del titular; cálculo del monto en el servidor; conciliación y antifraude.
Línea base. 0 pagos aplicados sobre cuentas ajenas; 100% de montos validados en servidor.

PF-13 · Expedientes y recibos entregados a ciudadanos

Activo A13 (Externo) · Control ISO: A.5.15 · A.8.3 · Hallazgos: 03

Estándar. ISO/IEC 27002 A.8.3 (Restricción de acceso a la información).
Directriz. El acceso a documentos ciudadanos se restringe por propiedad del objeto.
Procedimiento. Validación de propietario; identificadores no enumerables; registro de accesos a documentos.
Línea base. 0 accesos cruzados a expedientes/recibos.

PF-14 · Padrón de proveedores y contratos

Activo A14 (Externo) · Control ISO: A.5.20 · A.8.26 · Hallazgos: 14

Estándar. ISO/IEC 27002 A.5.20 (Gestión de la seguridad en acuerdos con proveedores).
Directriz. Todo vínculo contrato–proveedor se valida con la relación real y la autorización del solicitante.
Procedimiento. Verificación de asociación contrato – proveedor en el servidor; rechazo de combinaciones inconsistentes.
Línea base. 0 vínculos inconsistentes aceptados.

PF-15 · Firmware y paquetes del fabricante OT

Activo A15 (Externo) · Control ISO: A.5.21 · A.5.19 · A.8.30 · Hallazgos: 18

Estándar. ISO/IEC 27002 A.5.21 (Gestión de la seguridad en la cadena de suministro de TIC).
Directriz. Se exige firma y procedencia verificable del fabricante en todo paquete recibido.
Procedimiento. Verificación de firma y origen; acuerdos de seguridad con el fabricante; validación antes de instalar.
Línea base. 100% de paquetes firmados y verificados por el emisor.

PF-16 · Portal de transparencia y datos abiertos (observatorio)

Activo A16 (Externo) · Control ISO: A.5.12 · A.5.13 · A.8.12 · Hallazgos: 05, 15

Estándar. ISO/IEC 27002 A.5.12 (Clasificación de la información).
Directriz. La información se clasifica y revisa antes de publicarse en canales abiertos.
Procedimiento. Revisión editorial de publicaciones; depuración desactivada; ocultamiento de metadatos de arquitectura.
Línea base. 0 datos internos/arquitectura expuestos en el portal público.

PF-17 · Reportes ciudadanos (contenido generado por usuarios)

Activo A17 (Externo) · Control ISO: A.8.28 · A.8.23 · Hallazgos: 08

Estándar. ISO/IEC 27002 A.8.28 (Codificación segura).

Directriz. Todo contenido de usuario se sanea y se codifica en la salida según su contexto.

Procedimiento. Codificación de salida (HTML/atributo/JS); CSP estricta; validación de entrada.

Línea base. 0 incidencias de XSS almacenado.

PF-18 · Información y obligaciones regulatorias (CONAGUA / INAI)

Activo A18 (Externo) · Control ISO: A.5.31 · A.5.34 · A.5.36 · Hallazgos: Cumplimiento

Estándar. ISO/IEC 27002 A.5.31 (Requisitos legales, estatutarios y contractuales).

Directriz. Las obligaciones legales y regulatorias se inventarían y cumplen con evidencia.

Procedimiento. Inventario de obligaciones; reportes en tiempo; resguardo de evidencias de cumplimiento.

Línea base. 100% de obligaciones cumplidas en tiempo y forma.

PF-19 · Servicios y datos en la nube del proveedor de hosting

Activo A19 (Externo) · Control ISO: A.5.23 · A.5.19 · A.8.14 · Hallazgos: Disponibilidad

Estándar. ISO/IEC 27017 e ISO/IEC 27002 A.5.23 (Seguridad en servicios de nube).

Directriz. Los servicios en la nube operan bajo acuerdos de nivel de servicio y de seguridad verificados.

Procedimiento. Evaluación del proveedor; cifrado y segregación; respaldos y pruebas de restauración.

Línea base. SLA ≥ 99.9%; respaldos verificados mensualmente.

PF-20 · Accesos de soporte externo (cuenta soporte.ot)

Activo A20 (Externo) · Control ISO: A.8.2 · A.5.17 · A.5.18 · Hallazgos: 18

Estándar. ISO/IEC 27002 A.8.2 (Derechos de acceso privilegiado).

Directriz. El acceso de soporte externo es de mínimo privilegio, temporal y con MFA.

Procedimiento. Credenciales fuertes; MFA; expiración y revisión periódica de accesos privilegiados.

Línea base. 100% de accesos de soporte con MFA; revisión trimestral de privilegios.

Sección 06 — Planificación (gestión de riesgos)

6.1 Metodología

Se adopta ISO/IEC 27005. Para cada activo se identifica la amenaza y la vulnerabilidad (hallazgo), se estima la probabilidad (P) y el impacto (I) en escala 1–5, y el nivel de riesgo se calcula como R = P × I. Aceptación: Bajo (≤6) se acepta y monitorea; Medio (8–12) plan anual; Alto (15–16) prioridad; Crítico (20–25) tratamiento inmediato. El tratamiento preferente es mitigar aplicando el control del Anexo A, buscando prevenir, detectar, limitar o responder.

6.2 Matriz de riesgos

ID	Amenaza / vulnerabilidad	P	I	R	Nivel	Trat.	Control ISO
A01	Acceso no autorizado a datos personales (IDOR / BOLA) (H: 03, 11, 12)	5	5	**25**	**Crítico**	Mitigar	A.5.34 · A.8.3 · A.5.15
A02	Explotación de la aplicación (XSS almacenado, escalamiento de rol, fuga por errores) (H: 05, 06, 08)	4	4	**16**	**Alto**	Mitigar	A.8.28 · A.8.26 · A.8.9
A03	Abuso de autorización a nivel de objeto (BOLA) y endpoints no documentados (H: 11, 12)	4	4	**16**	**Alto**	Mitigar	A.8.26 · A.8.3 · A.5.15
A04	Exposición de código, respaldos y secretos en el document root (H: 01, 02, 04)	4	3	**12**	**Medio**	Mitigar	A.8.4 · A.8.9 · A.8.12
A05	Robo o uso de secretos expuestos y credenciales débiles (H: 01, 02, 10, 18)	4	5	**20**	**Crítico**	Mitigar	A.8.24 · A.5.17 · A.8.5
A06	Acceso no autorizado a la vista del proceso sin sesión de operador (H: 17)	4	4	**16**	**Alto**	Mitigar	A.5.15 · A.8.5 · A.8.16
A07	Cruce indebido IT→OT y divulgación de la arquitectura interna (H: 15, 16)	5	5	**25**	**Crítico**	Mitigar	A.8.22 · A.8.20 · A.8.12
A08	Enumeración o manipulación de la cadena de dependencias de proceso (H: 19)	4	4	**16**	**Alto**	Mitigar	A.5.15 · A.8.16 · ISO 27019
A09	Instalación de firmware no auténtico o con parámetros fuera de rango (H: 18, 20)	4	5	**20**	**Crítico**	Mitigar	A.8.19 · A.8.32 · A.8.24

ID	Amenaza / vulnerabilidad	P	I	R	Nivel	Trat.	Control ISO
A10	Falta de trazabilidad o alteración de registros (H: Transversal)	3	4	**12**	Medio	Mitigar	A.8.15 · A.8.16
A11	Exposición o robo de datos personales de terceros (H: 03, 12)	4	5	**20**	Crítico	Mitigar	A.5.34 · A.8.12 · A.5.14
A12	Manipulación de pagos y fraude sobre cuentas ajenas (H: 13)	3	5	**15**	Alto	Mitigar	A.8.26 · A.5.14 · A.8.9
A13	Acceso a documentos de otros ciudadanos (H: 03)	4	4	**16**	Alto	Mitigar	A.5.15 · A.8.3
A14	Validación indebida de vínculos y fraude en contrataciones (H: 14)	3	4	**12**	Medio	Mitigar	A.5.20 · A.8.26
A15	Compromiso de la cadena de suministro (firmware no firmado) (H: 18)	3	5	**15**	Alto	Mitigar	A.5.21 · A.5.19 · A.8.30
A16	Divulgación excesiva de información interna (H: 05, 15)	3	3	**9**	Medio	Mitigar	A.5.12 · A.5.13 · A.8.12
A17	Inyección de contenido malicioso (Stored XSS) (H: 08)	4	3	**12**	Medio	Mitigar	A.8.28 · A.8.23
A18	Incumplimiento regulatorio y sanciones (H: Cumplimiento)	2	4	**8**	Medio	Mitigar	A.5.31 · A.5.34 · A.5.36
A19	Pérdida de disponibilidad o acceso indebido del proveedor (H: Disponibilidad)	2	4	**8**	Medio	Mitigar	A.5.23 · A.5.19 · A.8.14
A20	Abuso de cuentas de soporte y credenciales débiles (H: 18)	3	4	**12**	Medio	Mitigar	A.8.2 · A.5.17 · A.5.18

Administración del riesgo. De los 20 riesgos, 5 son críticos, 7 altos y 8 medios. Los críticos (A01 datos de cuentas, A05 secretos, A07 frontera IT/OT, A09 firmware, A11 datos personales) concentran la prioridad porque habilitan la cadena que termina en el impacto operacional. El tratamiento se formaliza con responsable (Sección 08), fecha y evidencia, y el riesgo residual se reevalúa tras aplicar cada control.

Sección 07 — Soporte

7.1 Minuta de socialización del SGSI

Dato	Detalle
Reunión	Presentación y aprobación del SGSI de INTERAFAS
Fecha / lugar	14 de octubre de 2026 · Sala de Dirección General
Asistentes	Dirección General, CISO, Dir. TI, Dir. Operaciones (OT), Dir. Comercial, Dir. Administración, Unidad de Transparencia, Jurídico
Agenda	(1) Resultados del INTERAFAS-LAB; (2) alcance y política; (3) matriz de riesgos; (4) responsabilidades (RACI); (5) plan de concientización; (6) acuerdos.

Acuerdos

- Se aprueba el alcance, la política general y la designación formal del CISO con línea a la Dirección General.
- Se prioriza el tratamiento de los 5 riesgos críticos (A01, A05, A07, A09, A11) en el primer trimestre.
- Se instruye a TI y OT a corregir los hallazgos 16–20 (frontera IT/OT y firmware) como acción inmediata.
- Se aprueba el programa de concientización (flyer, curso y presentación) para personal y proveedores.

Áreas de oportunidad

- Ausencia de autorización a nivel de objeto en aplicaciones y API.
- Falta de segmentación efectiva IT/OT y de firma de firmware.
- Higiene de despliegue deficiente (artefactos y secretos expuestos).
- Cultura de seguridad incipiente; se requiere capacitación continua.

7.2 Soporte documental de prevención (flyer)

A partir de las amenazas de la matriz de riesgos se elabora el flyer de concientización (infografía) que se distribuye a todo el personal y a los proveedores. Reúne, en un solo material, los hábitos seguros y las conductas a evitar para prevenir, detectar y limitar los incidentes identificados.

INTERAFAS

¡Cuidamos el agua, cuidamos tu información!

La seguridad de la información es tarea de todos. En INTERAFAS protegemos los datos de la ciudadanía y la operación del agua con hábitos simples que todos aplicamos cada día.

01

Accesos seguros

Entra solo a tus datos y los de tu rol. Usa contraseñas fuertes y verificación en dos pasos (MFA).

02

Software confiable

Instala solo software y firmware firmado. No dejes respaldos, .bak ni secretos expuestos.

03

Frontera IT/OT

Respeta la segmentación: no cruces de IT a OT sin el firewall ni cambies parámetros fuera de rango.

¿Por qué importa?

En el ejercicio INTERAFAS-LAB, una fuga aparentemente menor se encadenó hasta un estado catastrófico del proceso de agua. Cada hábito seguro rompe esa cadena y protege el servicio y a las personas.

Reporta cualquier incidente de seguridad

ext. 2727

seguridad@interafas.gob

www.interafas.gob

Centro de Operaciones de Seguridad

Sección 08 — Operación (matriz RACI)

Responsabilidades sobre las actividades del SGSI. R = Responsable (ejecuta) · A = Aprobador (rinde cuentas) · C = Consultado · I = Informado.

Actividad del SGSI	DG	CISO	DTI	DOT	DCOM	DADM	JUR
Aprobar política y alcance del SGSI	A	R	C	C	C	C	C
Clasificar los activos de información	I	A	R	R	R	C	I

Actividad del SGSI	DG	CISO	DTI	DOT	DCOM	DADM	JUR
Control de accesos y autorización (IDOR/BOLA/rol)	I	A	R	C	C	I	I
Desarrollo seguro de aplicaciones y API	I	A	R	I	C	I	I
Gestión de secretos y credenciales	I	A	R	C	I	I	I
Segmentación y seguridad de red IT/OT	I	A	C	R	I	I	I
Gestión de firmware y cambios OT	I	C	I	R	I	I	I
Monitoreo, registro y detección	I	A	R	R	I	I	I
Respuesta a incidentes	I	A	R	R	C	I	C
Gestión de proveedores / cadena de suministro	I	C	C	C	I	R	C
Concientización y capacitación	I	A	C	C	R	C	I
Auditoría interna y evaluación	I	R	C	C	C	C	C
Cumplimiento legal y privacidad	A	C	I	I	C	I	R
Mejora continua del SGSI	A	R	C	C	C	C	C

DG = Dirección General · CISO = Oficial de Seguridad · DTI = Dir. TI · DOT = Dir. Operaciones (OT) · DCOM = Dir. Comercial · DADM = Dir. Administración · JUR = Jurídico.

Sección 09 — Evaluación del desempeño

Listas de verificación para determinar el cumplimiento y funcionamiento del SGSI. El estado actual refleja una primera auditoría con hallazgos aún abiertos, que alimenta la Sección 10.

Ítem	Criterio de verificación	Evidencia esperada	Estado
C.1	Autorización a nivel de objeto en el portal y la API (A01, A03, A11–A13)	0 accesos IDOR/BOLA en pruebas	Parcial
C.2	Desarrollo seguro: SAST/DAST, CSP y depuración desactivada en producción (A02, A17)	Pipeline con pruebas y CSP activa	Parcial
C.3	Secretos fuera del webroot, cifrados y con rotación; MFA de soporte (A05, A20)	Bóveda de secretos y MFA	No cumple
C.4	Artefactos de despliegue y respaldos fuera de la raíz web (A04, A16)	0 archivos sensibles públicos	No cumple
C.5	Segmentación efectiva IT/OT; sin autorización por cabeceras (A07)	Firewall OT y bloqueo de XFF	No cumple
C.6	Autenticación obligatoria en todos los endpoints OT (A06, A08)	0 endpoints OT sin sesión	No cumple
C.7	Firma de firmware verificada y validación de rangos de setpoint (A09, A15)	100% firmware firmado	No cumple
C.8	Registro y monitoreo de eventos de seguridad (A10)	Logging centralizado y alertas	Parcial
C.9	Validación de titularidad y montos en pagos (A12)	0 pagos sobre cuentas ajenas	Parcial
C.10	Cumplimiento legal y avisos de privacidad vigentes (A18, A11)	Inventario de obligaciones al día	Cumple

Resultado de la evaluación. 5 criterios “No cumple” (todos en el entorno OT y de higiene de despliegue), 4 “Parcial” y 1 “Cumple”. El SGSI es incipiente: la gobernanza está definida, pero los controles técnicos de los riesgos críticos aún no operan. Esto constituye una no conformidad mayor que se atiende en la Sección 10.

9.1 Indicadores (KPI)

- % de endpoints con autorización a nivel de objeto (meta 100%).
- % de firmware instalado con firma verificada (meta 100%).
- N.º de cruces IT→OT fuera del firewall (meta 0).
- % de personal que aprobó el curso de concientización (meta ≥ 90%).
- Tiempo medio de detección y de respuesta a incidentes (tendencia a la baja).

Sección 10 — Mejora

Con base en el checklist de auditoría (Sección 09), se documentan las no conformidades, se rediseña el soporte de prevención y se mejora la política funcional que no logró su objetivo (ISO/IEC 27001, cláusula 10).

10.1 No conformidad y acción correctiva

Campo	Detalle
No conformidad	Los controles técnicos de los riesgos críticos de OT no operan: endpoints OT sin autenticación (C.6), firmware sin firma (C.7) y frontera IT/OT sin segmentación (C.5).
Control incumplido	A.8.22 (Segregación de redes), A.8.19 (Instalación de software), A.5.15 (Control de acceso).
Causa raíz	Confianza mal ubicada en datos del cliente y en la integridad sin autenticidad; ausencia de arquitectura de segmentación.
Corrección inmediata	Bloquear el uso de X-Forwarded-For para autorización; exigir sesión de operador; deshabilitar la instalación de firmware sin firma.
Acción correctiva	Implementar firewall/DMZ OT, verificación de firma del fabricante y validación de rangos de setpoint; reevaluar el riesgo residual.
Responsable / plazo	Dir. Operaciones (OT) con CISO · 90 días · evidencia verificable en la siguiente auditoría.

10.2 Política funcional mejorada (PF-A07 — frontera IT/OT)

La política funcional del activo A07 (gateway RTU-GW-07 / frontera IT/OT) no logró su objetivo (línea base “0 cruces IT→OT”). Se rediseña reforzando prevención, detección y respuesta:

PF-07 (mejorada) · Frontera IT/OT y gateway operacional

Activo A07 (Interno) · Control ISO: A.8.22 · A.8.20 · A.8.16 · A.8.26 · Hallazgos: 15, 16

Estándar. ISO/IEC 27002 A.8.22 (Segregación de redes) e IEC 62443 (zonas y conductos).

Directriz. El tráfico IT→OT sólo transita por un conducto controlado (firewall/DMZ OT); el origen jamás se determina con cabeceras del cliente; la arquitectura interna no se divulga.

Procedimiento. (Prevención) firewall industrial con lista blanca y autenticación mutua; (Detección) monitoreo y alertas de todo intento de cruce y de spoofing de X-Forwarded-For; (Respuesta) bloqueo automático y aislamiento de la sesión; revisión trimestral de reglas.

Línea base. 0 cruces IT→OT fuera del firewall; 100% de intentos de cruce alertados en ≤ 5 min; 0 metadatos de arquitectura expuestos.

10.3 Soporte de prevención rediseñado

El material de concientización se actualiza con el aprendizaje de la auditoría, añadiendo un mensaje específico de frontera IT/OT y un microcurso obligatorio para Operaciones:

